PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Feuille de route sécurité numérique 2026-2027

03-860 SGDSN et ANSSI - Feuille de route de la sécurité numérique de l'État 2026-2027 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La feuille de route est validée par le COSINUS et s'appuie sur l'instruction générale interministérielle numéro 1337.
2. L'homologation de sécurité est une obligation réglementaire qui doit être renouvelée lors d'une migration vers le cloud.
3. La transition vers la cryptographie post-quantique vise à contrer les futurs ordinateurs quantiques capables de casser les mécanismes actuels.

Cadre et gouvernance

Notion	À retenir
Origine	Prévue par l'**IGI 1337**, annuelle, validée en **COSINUS** puis concertation interministérielle ; 2025-2026 : conformité **NIS 2** (art. 20-21) ; 2026-2027 : après les intrusions de **2025**, échéances affermies, ajout du **post-quantique**.
Suivi au plus haut niveau	**1a** conseiller numérique au cabinet sous **1 mois** ; **1c** rapports annuels des établissements (décret **2019-1088**) au **30/06/2026**.
Déclinaison et contrôle	**1d** déclinaison ministérielle avant le **30/06/2026** ; **1e** lettres de mission ; **1f** inspections ; **1g** politique d'audit au **30/06/2026**, appliquée au **31/12/2026** ; PSSIE intégrant NIS 2 au **T1 2027**.

Homologation et prestataires

Notion	À retenir
Obligation	Avant toute mise en œuvre (sauf dispense) ; migration **cloud** = **nouveau système** ; politique cloud au **30/06/2026**.
Échéances	Inventaire des SI à enjeux au **30/06/2026** ; missions essentielles homologuées au **31/12/2026**, autres SI à enjeux au **31/12/2028** ; risques résiduels présentés en commission.
Prestataires	Niveau au moins équivalent au site ; **3a** clauses proportionnées : marchés numériques fin **2026**, à composante numérique fin **2027** ; **3b** contrôle de la chaîne d'approvisionnement au **30/06/2026**.

Maintien en condition et services exposés

Notion	À retenir
Correctifs et alertes	Procédures au **30/06/2026** (correctifs appliqués avant le **31/12/2026**) ; cartographie préalable.
Obsolescence	Briques de sécurité remplacées au **31/12/2026**, autres éléments des SI à enjeux avant le **1er mars 2028** ; sinon **mesures d'atténuation** ANSSI.
DNS et messagerie	Vecteurs privilégiés des attaques : **DNS** renforcé au **30/09/2026** (service interministériel DNS), **messagerie** au **31/12/2026**.

Identités, authentification, administration

Notion	À retenir
Identités et droits	Cycle de vie automatisé (bases RH) : SI à enjeux fin **2026**, étendu fin **2027** ; revue annuelle des droits (admin technique **30/06/2026**, fonctionnelle **31/12/2026**) ; démarche **Zéro Trust**.
MFA et fédération	MFA utilisateurs : SI à enjeux **28/02/2027**, tous les SI **28/02/2028** ; **ProConnect** généralisé ; comptes génériques supprimés au **30/06/2026**.
Administration	MFA de **tous les administrateurs** au **31/12/2026** ; **postes dédiés** (SI à enjeux fin 2026, services déconcentrés fin 2027) ; annuaires au niveau **3** de l'indicateur **ADS** au **30/06/2026**.

Supervision, reprise, post-quantique

Notion	À retenir
Détection et CSIRT	Traces, **EDR/XDR** sur tous postes et serveurs, CSIRT ministériels consolidés au **31/12/2026** ; partage avec le **CERT-FR** sans validation préalable ; point de suivi **6 mois** après un incident important (ANSSI, inspection, Premier ministre).
Plans de reprise	Testés **au moins une fois par an** ; premier test des sauvegardes des SI à enjeux (à partir du 31/03/2025) d'ici le **30 juin**.
Post-quantique	Menace « capter maintenant, déchiffrer plus tard » ; inventaire des données durablement sensibles fin **2026**, briques techniques fin **2027**, **SI DR** protégés avant fin **2030**, puis seuls des produits post-quantiques.

Pièges et confusions

- ⚠ Confondre l'échéance de l'authentification multifacteur des administrateurs (fin 2026) avec celle des utilisateurs (28 février 2027 pour les systèmes à enjeux).
- ⚠ Croire que l'inventaire post-quantique se termine en 2030 alors que 2030 est l'horizon de mise en œuvre.
- ⚠ Penser qu'une migration vers le cloud ne nécessite pas de nouvelle homologation.
- ⚠ Croire qu'un CSIRT ministériel doit obtenir une validation interne avant de partager une information avec le CERT-FR.
- ⚠ Oublier que la revue des droits des comptes admin technique doit être faite d'ici le 30 juin 2026.

Sigles et définitions

COSINUS	comité stratégique de la sécurité numérique qui valide la feuille de route
Homologation de sécurité	obligation de faire valider la sécurité des infrastructures et services logiciels de l'État avant leur mise en œuvre
Zéro Trust	démarche de sécurité qui vérifie systématiquement l'identité, l'authentification et les droits avant tout accès
ProConnect	mécanisme de fédération des identités des services numériques de l'État
EDR ou XDR	dispositif avancé de détection et de réponse aux attaques sur les postes de travail et les serveurs
CSIRT ministériel	centre d'alerte et de réaction aux cyberattaques d'un ministère
CERT-FR	centre de réponse à incident national et gouvernemental porté par l'ANSSI

Auto-test

1. Quel organisme valide la feuille de route de la sécurité numérique ?
2. Quelle est la date limite pour la sécurisation du DNS ?
3. Que doit-on faire pour les versions vulnérables ou obsolètes sans mise à jour ?
4. Avant quelle date les SI Diffusion Restreinte doivent-ils intégrer la cryptographie post-quantique ?
5. Quels services exposés les cyberattaques contre l'État exploitent-elles de manière privilégiée ?

Réponses : **1.** Le COSINUS · **2.** 30 septembre 2026 · **3.** Appliquer des mesures d'atténuation conformes aux recommandations de l'ANSSI · **4.** Fin 2030 · **5.** Le DNS et la messagerie

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.